
Implementación de un SIEM para la Detección y Respuesta Automatizada de Amenazas

Wazuh • VirusTotal • Gemini

nick240202@gmail.com, entusiasta de la ciberseguridad y SOC

2026-08-08

Índice

1	Informe del Examen de Respondedor a Incidentes de Seguridad Ofensiva	1
1.1	Introducción	1
1.2	Objetivo	1
1.3	Requisitos	1
2	Ejecutivo Resumen	3
2.1	Visión general de detección e identificación de incidentes	3
2.2	Camino de Ataque de Alto Nivel	3
2.3	Resumen del análisis forense	4
3	Detección e identificación de incidentes	5
3.1	Contención, erradicación y recuperación	6
3.2	Hallazgos	7
4	Forense Análisis	8
4.1	Análisis de imágenes de disco	8
4.2	Análisis de malware	12
5	Conclusión	17

1 SIEM Implementation

1.1 Introducción

El presente informe documenta la implementación de una solución de gestión de eventos e información de seguridad (SIEM) basada en Wazuh, orientada a la detección, identificación, análisis y respuesta ante amenazas de seguridad.

La solución integra VirusTotal como fuente de inteligencia de amenazas para el análisis de indicadores de compromiso y Gemini como herramienta de apoyo para el análisis contextual de las alertas. Asimismo, se utiliza Wazuh Active Response para automatizar acciones de contención y erradicación frente a amenazas identificadas.

El informe presenta el proceso de implementación, las configuraciones realizadas, las evidencias obtenidas y los resultados de las pruebas ejecutadas en un entorno controlado.

1.2 Objetivo

El objetivo es implementar y validar un flujo automatizado de detección y respuesta que permita identificar amenazas mediante Wazuh, enriquecer los eventos utilizando VirusTotal, analizar las alertas mediante Gemini y ejecutar acciones de respuesta mediante Wazuh Active Response.

La solución busca reducir la intervención manual del analista SOC y mejorar los tiempos de detección, análisis y respuesta ante incidentes de seguridad.

1.3 Requisitos

El presente informe incluye las siguientes secciones:

- **Resumen ejecutivo:** descripción general de la solución, arquitectura y flujo de detección y respuesta.
- **Detección e identificación de incidentes:** documentación de los eventos detectados por Wazuh, las reglas activadas, los indicadores de compromiso obtenidos y las evidencias asociadas.

- **Integración con VirusTotal:** descripción del proceso de consulta y análisis de hashes mediante la API de VirusTotal para determinar la reputación de los archivos detectados.
- **Análisis asistido mediante Gemini:** documentación del proceso utilizado para enviar información de las alertas a Gemini y obtener análisis contextual y recomendaciones para el tratamiento del incidente.
- **Contención, erradicación y recuperación:** descripción de las acciones ejecutadas mediante Wazuh Active Response para contener y eliminar la amenaza, así como la posterior verificación del endpoint.
- **Análisis forense:** análisis de los eventos, archivos, hashes, procesos e indicadores relacionados con las amenazas detectadas.
- **Hallazgos:** presentación cronológica de los eventos identificados, evidencias obtenidas, resultados del análisis y acciones ejecutadas.
- **Conclusión:** evaluación de los resultados obtenidos y de la efectividad de la solución implementada.

Las secciones de detección, análisis y respuesta incluirán las configuraciones, comandos, evidencias y capturas de pantalla necesarias para demostrar y reproducir el funcionamiento de la solución.

2 Resumen ejecutivo

2.1 Visión general de detección e identificación de incidentes

La solución fue implementada y validada en un entorno de laboratorio con endpoints Windows 11 y Linux Mint, utilizando agentes de Wazuh. Se realizaron pruebas controladas mediante EICAR y AMTSO para evaluar la detección de archivos potencialmente maliciosos. Wazuh generó las alertas correspondientes y los indicadores obtenidos fueron consultados mediante la API de VirusTotal para determinar su reputación. Adicionalmente, Gemini permitió enriquecer y analizar las alertas.

2.2 Camino de Ataque de Alto Nivel

El flujo implementado para la detección y respuesta fue el siguiente:

1. Windows 11 y Linux Mint: generación de eventos mediante las pruebas EICAR y AMTSO.
2. Wazuh: detección de los eventos, generación de alertas y obtención de indicadores de compromiso.
3. VirusTotal, Gemini y Active Response: enriquecimiento y análisis de las alertas, seguido de la ejecución de acciones automatizadas de respuesta y verificación del endpoint.

2.3 Resumen del análisis forense

El análisis forense se realizó sobre los eventos y archivos registrados en los endpoints Windows 11 y Linux Mint durante las pruebas controladas. A partir de las alertas generadas por Wazuh, se analizaron los archivos detectados, sus hashes SHA-256, procesos relacionados e indicadores de compromiso. Estos indicadores fueron contrastados mediante la API de VirusTotal, permitiendo obtener información adicional sobre la reputación de los archivos y sus detecciones.

Asimismo, Gemini fue utilizado para complementar el análisis y proporcionar contexto sobre las alertas e indicadores identificados. Finalmente, se revisaron las acciones ejecutadas mediante Wazuh Active Response, verificando la contención y erradicación de los archivos detectados y el estado final de los endpoints. Los resultados permitieron validar el flujo de detección, análisis y respuesta automatizada implementado.

3 Detección e identificación de incidentes

La solución fue implementada en un entorno de laboratorio compuesto por dos endpoints, Windows 11 y Linux Mint, ambos monitorizados mediante agentes de Wazuh. Como se observa en la Figura 3.1, los dos agentes se encuentran activos y reportando eventos al servidor Wazuh, permitiendo centralizar la información generada durante las pruebas de seguridad.

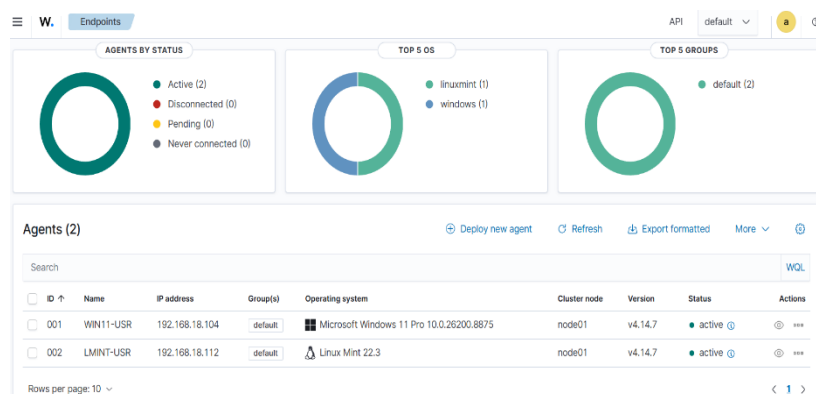


Figura 3.1: Endpoints Windows 11 y Linux Mint monitorizados mediante Wazuh

Una de las alertas escaladas se llama "Aplicaciones Maliciosas" y monitoriza los eventos recopilados para detectar la aparición de hashes SHA-256 de aplicaciones maliciosas conocidas que son comúnmente utilizadas por actores amenazadores como Mimikatz y NetExec. La alerta solo se activó una vez por un evento registrado el 11/01/2024 a la 1:11:11 AM.

Dado que los eventos que contienen información sobre el uso de aplicaciones que son comúnmente utilizadas por atacantes pueden tener graves implicaciones, repasemos este evento con más detalle.



Figura 3.2: ImgPlaceholder

El evento nos proporciona varias informaciones importantes que pueden aprovecharse en nuestro proceso de detección e identificación de incidentes:

- Nombre de usuario: Administrador
- Nombre del archivo: Zwetsch.exe
- Directorio: C:\hackingtools\

Basándonos en el hash SHA-256 correspondiente y el característico argumento de línea de comandos "sekurlsa::logonpasswords", podemos estar seguros de que se trata de Mimikatz.

[...]

3.1 Contención, erradicación y recuperación

Una vez confirmado el compromiso de PC1, PC2 y SRV1, se implementaron medidas inmediatas de contención. Las máquinas afectadas quedaron aisladas de la red para evitar más desplazamientos laterales y cortar la comunicación con la infraestructura de mando y control (C&C) del atacante.

La fase de erradicación comenzó con una auditoría exhaustiva de todas las cuentas locales de los Administradores en todo el entorno para asegurar que las contraseñas fueran únicas y seguras. La contraseña local compartida del administrador entre PC1 y PC2 fue reemplazada por contraseñas nuevas y seguras en ambas máquinas. También se identificaron y remediaron otros sistemas que usaban la misma contraseña original. Cuentas de usuario que tenían

Las credenciales en caché en PC2, probablemente extraídas por el atacante usando Mimikatz, se restablecieron. Se restauraron copias de seguridad limpias en PC1, PC2 y SRV1 para eliminar cualquier amenaza residual, y se actualizaron las contraseñas de sus cuentas de administrador local. Para reforzar aún más la seguridad, se restablecieron todas las contraseñas locales de las cuentas de Administrador y de usuario, y se aplicó una política estricta de contraseñas, junto con mecanismos de bloqueo de cuentas, para prevenir futuros ataques con contraseñas.

3.2 Hallazgos

Marca temporal	Observación	Afectados Activos
01/09/2024 15:25:00	¡Comienzo del rociado de contraseñas con contraseña Password1!	Presentador: PC1
01/09/2024 15:58:00	Fin de la aplicación de contraseñas.	Presentador: PC1
01/09/2024 15:58:15	Inicio de sesión exitoso para un usuario administrador local	Anfitrión: PC1 Usuario: Administrador (local)
01/09/2024 15:59:00	Descargar meterpreter.exe de <IP> vía navegador	Anfitrión: PC1 Usuario: Administrador (local)
01/09/2024 15:59:49	Creación de procesos de meterpreter.exe	Anfitrión: PC1 Usuario: Administrador (local) Máquina objetivo: PC2 Usuario objetivo: Administrador (local) Contraseña: ¡Contraseña1!"
01/09/2024 16:05:11	Creación de procesos de PsExec	
[...]	[...]	[...]
11/01/2024 1:11:11 AM	Creación de procesos de Zwetsch.exe	Anfitrión: PC2 Usuario: Administrador (local)
[...]	[...]	[...]

4 Análisis Forense

4.1 Análisis de imágenes de disco

Comenzamos el análisis de la imagen de disco proporcionada cargándola en Autopsia y habilitando el plugin "Recientes Actividades". Una vez terminado el análisis de la imagen del disco, tendremos varias opciones para comenzar nuestra investigación.



Figura 4.1: ImgPlaceholder

Según la información compartida por el otro equipo de respuesta a incidentes, se ha registrado una descarga . Por lo tanto, empecemos analizando las "Descargas Web" bajo "Artefactos de Datos". Una entrada llama nuestra atención que indica que offer.7z fue descargado desde 192.168.48.130:8000.



Figura 4.2: ImgPlaceholder

Vamos a comprobar si este archivo existe en el directorio de Descargas del usuario Admin donde fue descargado. Si es así, intentemos extraerlo.



Figura 4.3: Marcaposición de imagen

Por desgracia, nos piden una contraseña. Como no tenemos contraseña, nuestro intento de extracción falla.



Figura 4.4: ImgPlaceholder

En este punto, pensemos en cómo podríamos obtener una contraseña así. Una posibilidad es asumir que el atacante solo tenía acceso vía CLI y, por tanto, podría haber usado PowerShell para extraer el archivo. Además, basándonos en la información del sistema, sabemos que el registro de bloques de scripts de PowerShell está habilitado. Vamos a echar un vistazo al Visor de Eventos de Inicio de sesión Operativo de PowerShell y buscar "offer.7z".

Esto revela el siguiente evento:



Figura 4.5: ImgPlaceholder

El evento contiene la información de que se utilizó el superpase de contraseña para extraer el archivo. Probemos esta contraseña y extraigamos los archivos usando 7z. Una vez extraído el archivo, aparece un nuevo binario llamado "viruz.exe". El laboratorio pide el hash del archivo de este binario, que podemos obtener mediante el Cmdlet Get-FileHash: 2D51EF5F421E844EC1278CDAAA1830105D1F879A163AF55EA826B428A0A97E68.



Figura 4.6: ImgPlaceholder

4.2 Análisis de malware

El segundo laboratorio de la fase de Análisis Forense solicita analizar el binario del laboratorio anterior y obtener un token que el actor de la amenaza utiliza para autenticarse en su infraestructura C&C. Empecemos iniciando una sesión administrativa de PowerShell.



Figura 4.7: ImgPlaceholder

Luego, naveguemos al directorio correcto y ejecutemos el binario.



Figura 4.8: ImgPlaceholder

El binario devuelve la información de que falta un token. En este punto, podemos usar análisis estático o dinámico. Usaremos análisis dinámico con ProcMon y empezaremos añadiendo un filtro para viruz.exe.



Figura 4.9: ImgPlaceholder

Una vez que volvamos a ejecutar el binario, veremos las siguientes entradas en ProcMon. Una entrada muestra un resultado "NOMBRE NO ENCONTRADO" para el archivo
C:\windows\token.

student@youremailaddress.com OSID: OS-



Figura 4.10: ImgPlaceholder

Usando la ruta de prueba del cmdlet, comprobemos si el archivo existe:



Figura 4.11: ImgPlaceholder

Como era de esperar, el archivo no existe. Para resolver este problema, creemos este archivo como archivo vacío con el Cmdlet New-Item.



Figura 4.12: ImgPlaceholder

Una vez hecho, vamos a volver a ejecutar el binario.



Figura 4.13: ImgPlaceholder

Ahora, el binario devuelve la información "Esperando token..." en lugar del error anterior. Además, no termina a sí mismo, sino que espera, presumiblemente, la entrada de algún tipo de token. Vamos a limpiar la pantalla de ProcMon y volver a ejecutar el binario para ver qué hace el student@youremailaddress.com OSID: OS-

binario.

[...]

5 Conclusión

Nuestro proceso de detección e identificación de incidentes descubrió con éxito tres sistemas comprometidos dentro de la infraestructura de Megacorp One, junto con la exfiltración de nuestra receta confidencial de magdalenas de chocolate.

Durante el análisis forense, se reveló que el actor de la amenaza descargó un archivo protegido por contraseña en uno de los sistemas comprometidos, extrayendo un binario malicioso. Este binario aprovechaba tokens temporales para asegurar un token de autenticación vinculado a la infraestructura de Mando y Control (C&C) del actor de amenazas. Al obtener este token de autenticación, obtuvimos valiosos conocimientos sobre las operaciones del actor amenazante, mejorando nuestra capacidad para defendernos de futuros ataques.

Mediante una rápida contención, recuperación de los sistemas comprometidos y erradicación de los artefactos maliciosos, mitigamos con éxito la amenaza y evitamos un mayor compromiso del entorno de Megacorp One.